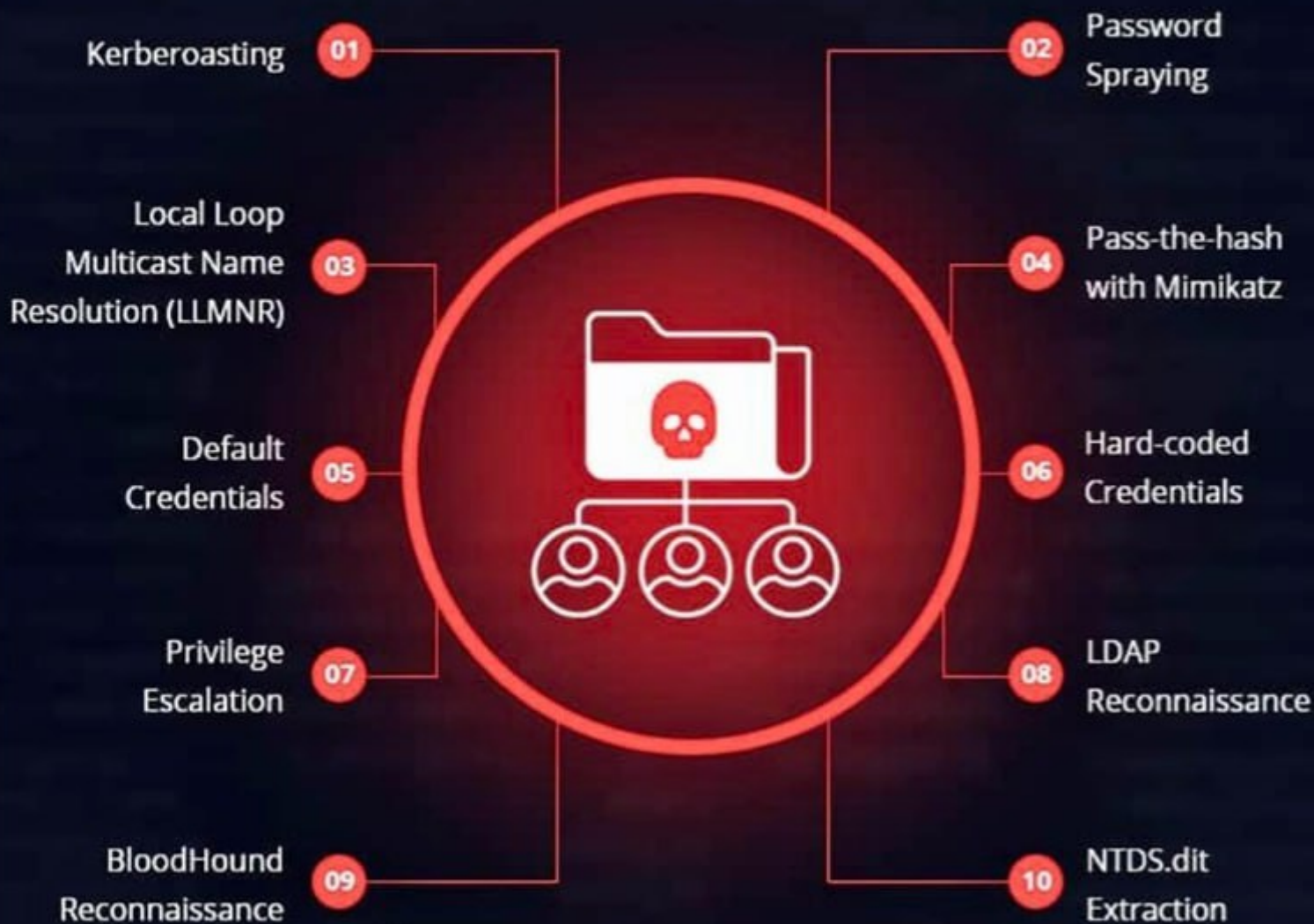




Top 10 Active Directory





Top 10 Most Dangerous Active Directory Attack Methods

۱۰ مورد از خطرناک ترین روش حمله به Active Directory



تهیه شده توسط تیم TryHackBox

The Chaos



لینک زیر جهت حمایت از جامعه آموزش رایگان :

<https://daramet.com/TryHackBox>

ما را به دوستانتان معرفی کنید .

دیگر کانال ها و شبکه های اجتماعی ما را دنبال کنید:

کانال های تلگرام ما

آموزش تست نفوذ و Red Team :

[@TryHackBox](https://t.me/TryHackBox)

رودمپ های مختلف:

[@TryHackBoxOfficial](https://t.me/TryHackBoxOfficial)

داستان های هک:

[@TryHackBoxStory](https://t.me/TryHackBoxStory)

آموزش برنامه نویسی:

[@TryCodeBox](https://t.me/TryCodeBox)

رادیو زیروپاد (پادکست ها):

[@RadioZeroPod](https://t.me/RadioZeroPod)

اینستاگرام :

<http://www.instagram.com/TryHackBox>

یوتیوب:

<https://youtube.com/@tryhackbox>

TryHackBox



بخش اول: Active Directory (AD)

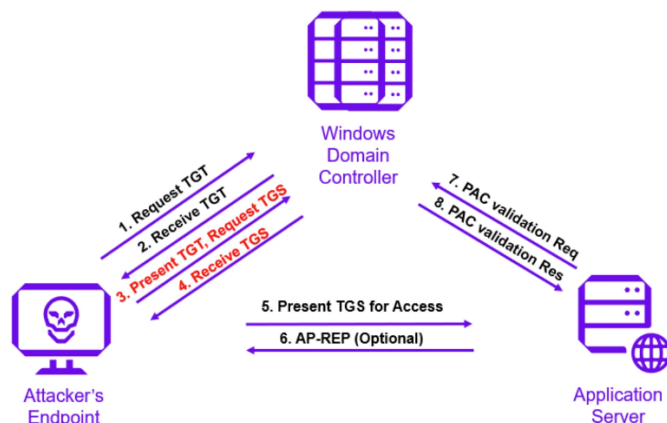
۱.۱ مقدمه کلی

Active Directory (AD) ستون فقرات زیرساخت‌های فناوری اطلاعات بیشتر سازمان‌ها در سراسر جهان است. این سامانه به عنوان یک مرکز کنترل متمرکز برای مدیریت هویت کاربران، مجوزهای دسترسی و منابع شبکه عمل می‌کند و آن را به یک هدف حیاتی و جذاب برای مهاجمان سایبری تبدیل کرده است. نقض امنیت **Active Directory** می‌تواند به پیامدهای شدیدی منجر شود؛ از سرقت داده‌های حساس و افزایش امتیازات دسترسی گرفته تا اختلال کامل در عملیات و حتی استقرار باج‌افزارهای مخرب. با افزایش پیچیدگی حملات سایبری، درک خطرناک‌ترین روش‌هایی که مهاجمان برای هدف قرار دادن **Active Directory** استفاده می‌کنند برای محافظت از دارایی‌های دیجیتال سازمان‌ها ضروری است.

بخش دوم: توضیح ۱۰ مورد از خطرناک‌ترین روش حمله به Active Directory

۱.۲ Kerberoasting :

Kerberoasting یک تکنیک دسترسی به اعتبار است که پروتکل احراز هویت **Kerberos** را هدف قرار می‌دهد. این پروتکل معمولاً در شبکه‌های ویندوزی برای احراز هویت امن کاربران و دستگاه‌ها استفاده می‌شود. در این حمله، مهاجم با درخواست بلیط‌های **Kerberos** مرتبط با حساب‌های سرویس که دارای **Service Principal Names (SPNs)** هستند، سعی می‌کند آن‌ها را به صورت آفلاین کرک کرده و رمزعبورها را استخراج کند.



• نحوه عملکرد حمله:

حمله با دسترسی اولیه مهاجم به یک حساب کاربری عادی در دامنه آغاز می‌شود. سپس مهاجم SPN‌های مرتبط با حساب‌های کاربری، به ویژه آن‌هایی که ممکن است ضعیف یا دارای امتیازات بالا باشند، را شناسایی می‌کند. در مرحله بعد، مهاجم برای این SPN‌ها از سرویس احراز هویت Kerberos، Service Tickets (TGS tickets) درخواست می‌کند. این بلیط‌ها با استفاده از هش رمزعبور حساب سرویس رمزگذاری شده‌اند. پس از به دست آوردن بلیط‌های رمزگذاری شده، مهاجم هش‌های رمزعبور را از آن‌ها استخراج کرده و سعی می‌کند آن‌ها را با استفاده از حملات Brute-Force یا Dictionary به صورت آفلاین کرک کند. این کار بدون نیاز به تعامل مستقیم با سرور احراز هویت انجام می‌شود و تشخیص حمله را دشوار می‌سازد. پس از کرک رمزعبور، مهاجم می‌تواند از آن برای افزایش امتیازات یا حرکت جانبی در شبکه استفاده کند.

TryHackBox

• ابزارهای رایج:

ابزارهای متداول در حملات Kerberoasting شامل Mimikatz، Rubeus، Impacket (به ویژه ماژول GetUserSPNs) و Powersploit هستند. برای کرک هش‌ها نیز از ابزارهایی مانند Hashcat و JohnTheRipper استفاده می‌شود.



• تأثیر و ریسک‌ها:

حملات Kerberoasting به ویژه خطرناک هستند زیرا اغلب تشخیص و پیشگیری از آن‌ها دشوار است. هر حساب کاربری عادی در دامنه می‌تواند برای هر SPN درخواست بلیط سرویس دهد و Domain Controller معمولاً بررسی نمی‌کند که آیا کاربر مجوز دسترسی به آن سرویس را دارد یا خیر. این امر به مهاجمان اجازه می‌دهد بدون فعال کردن هشدارها، بلیط‌ها را به دست آورده و سعی در کرک آن‌ها کنند. پس از به دست آوردن رمزعبورها، مهاجمان می‌توانند کل دامنه Active Directory را به خطر بیندازند. این نوع حمله از این واقعیت سوءاستفاده می‌کند که رمزعبورهای مرتبط با SPN‌ها اغلب ضعیف یا تکراری هستند و باعث می‌شود با ابزارهای پیشرفته در عرض چند ساعت کرک شوند.

• تشخیص و پاسخ:

برای تشخیص حملات Kerberoasting، باید Event IDs 4768 و 4769 را زیر نظر گرفت و به دنبال درخواست‌های غیرعادی TGS بود. ابزارهای نظارت بر Active Directory و SIEM می‌توانند به ردیابی رفتارهای غیرعادی و ارتباط فعالیت‌های شبکه با هویت کاربران کمک کنند. تشخیص زودهنگام چالش‌برانگیز است زیرا درخواست‌های بلیط متداول هستند و شناسایی درخواست‌های غیرعادی دشوار است. در صورت تشخیص، حساب‌های به خطر افتاده باید غیرفعال شده، رمزعبور حساب‌های سرویس تغییر کند، لاگ‌ها بررسی شده و به کاربران درگیر و مسموم شده اطلاع رسانی شود.

• راهکارهای کاهش و پیشگیری:

پیشگیری از حملات Kerberoasting نیازمند یک رویکرد چندوجهی است. باید سیاست‌های رمزعبور قوی و پیچیده برای حساب‌های سرویس، به ویژه آن‌هایی که با SPN‌ها مرتبط هستند، اعمال شود. استفاده از Group Managed Service Accounts

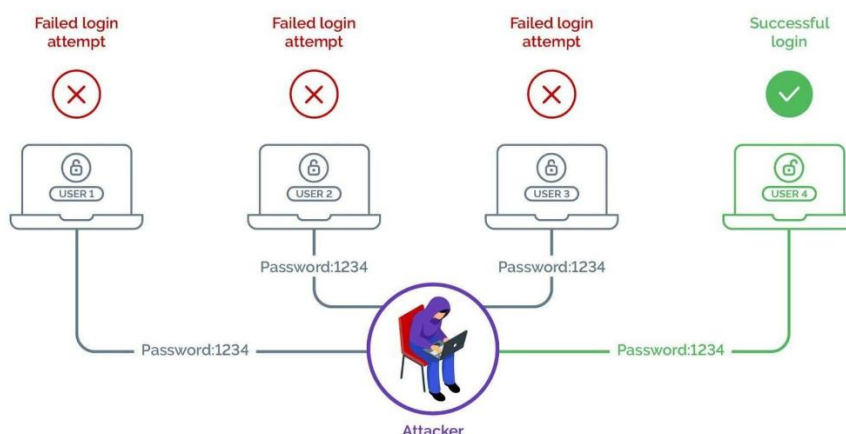


(gMSAs) ترجیح داده می‌شود زیرا این حساب‌ها به صورت خودکار رمزعبورهای تصادفی و پیچیده تولید کرده و آن‌ها را به روز می‌کنند. حساب‌های **Active Directory** باید به طور منظم ممیزی شوند. پیاده‌سازی احراز هویت چندعاملی (MFA) نیز می‌تواند اثرگذاری این حملات را کاهش دهد. همچنین ضروری است که اصل کمترین امتیاز (**Least Privilege**) اعمال شود تا حساب‌های سرویس تنها در صورت ضرورت دسترسی، مجوزهای مدیریتی دریافت کنند.

۲.۲ Password Spraying :

Password Spraying یک تکنیک حمله سایبری است که در آن مهاجمان با امتحان کردن تعداد کمی از رمزعبورهای رایج در مقابل تعداد زیادی از حساب‌های کاربری، سعی در دسترسی غیرمجاز دارند. این روش با حملات **Brute-Force** سنتی متفاوت است که بر روی یک حساب واحد با رمزعبورهای زیاد تمرکز می‌کنند، زیرا **Password Spraying** هدفش جلوگیری از فعال شدن مکانیسم‌های قفل کردن حساب به دلیل تلاش‌های مکرر ناموفق ورود است.

How Password Spraying Works





• نحوه عملکرد حمله:

حمله معمولاً با یک مرحله شناسایی آغاز می‌شود، جایی که مهاجم فهرستی از نام‌های کاربری یا آدرس‌های ایمیل معتبر را جمع‌آوری می‌کند که می‌تواند از منابع عمومی یا نشت‌های داده قبلی به دست آید. سپس مهاجم چند رمزعبور رایج یا ضعیف مانند "123456"، "qwerty، password" یا تغییراتی از نام شرکت را انتخاب می‌کند. در مرحله بعد، از ابزارهای خودکار برای امتحان سیستماتیک این رمزعبورها در تعداد زیادی از حساب‌ها استفاده می‌شود. برای جلوگیری از تشخیص و قفل شدن حساب‌ها، مهاجم تلاش‌های ورود را در طول ساعت‌ها یا روزها توزیع می‌کند و ممکن است از چندین آدرس IP یا تغییر منطقه زمانی استفاده کند تا با الگوهای معمول ورود ادغام شود. در صورت موفقیت آمیز بودن حمله، مهاجم می‌تواند به داده‌های حساس دسترسی غیرمجاز پیدا کند، حرکت جانبی در شبکه انجام دهد یا حتی باج‌افزار مستقر کند.

• ابزارهای رایج:

ابزارهای متداول در حملات Password Spraying شامل [dafthack/DomainPasswordSpray](https://github.com/dafthack/DomainPasswordSpray)، [iom0ath/SharpSpray](https://github.com/iom0ath/SharpSpray) و [MSOLSpray](https://github.com/MSOLSpray) هستند.

• تأثیر و ریسک‌ها:

حملات موفق Password Spraying می‌تواند منجر به نشت گسترده داده‌ها، زیان‌های مالی قابل توجه و آسیب به اعتبار سازمان شود. مهاجمان می‌توانند حساب‌های مشتریان یا کارمندان را به خطر بیندازند که منجر به فعالیتهای متقلبانه یا دسترسی به اطلاعات شخصی حساس می‌شود. این حملات یک وسیله مؤثر برای دسترسی اولیه یا افزایش امتیاز هستند، به ویژه اگر احراز هویت چندعاملی (MFA) فعال نباشد. طبق برآورد مایکروسافت، حملات Password Spraying مسئول بیش از یک سوم همه compromises حساب در سازمان‌ها هستند.



• تشخیص و پاسخ:

برای تشخیص حملات Password Spraying، باید الگوهای ورود غیرعادی مانند چندین تلاش ناموفق ورود در حسابهای مختلف در بازه‌های زمانی کوتاه را زیر نظر گرفت. ناسازگاری‌های جغرافیایی و آدرس‌های IP غیرمنتظره نشانه‌های مهمی هستند. سیستم‌های SIEM، فایروال‌های برنامه‌های تحت وب (WAF)، مکانیسم‌های محدود کردن نرخ (rate limiting) و تشخیص بات می‌توانند به شناسایی و مسدود کردن این فعالیت‌ها کمک کنند.

• راهکارهای کاهش و پیشگیری:

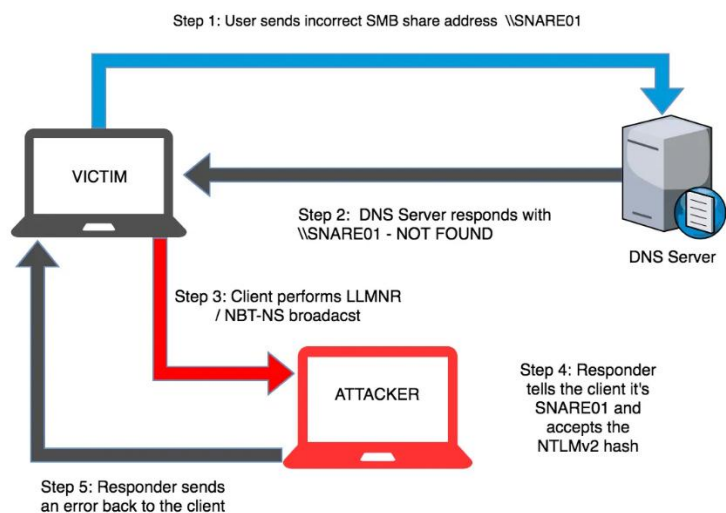
احراز هویت چندعاملی (MFA) اولین و مؤثرترین خط دفاعی در برابر حملات Password Spraying است، زیرا حتی اگر مهاجم رمزعبور را حدس بزند، نیاز به یک لایه تأیید اضافی دارد.

- باید سیاست‌های رمزعبور قوی اعمال شود که طول حداقل ۱۲-۱۴ کاراکتر، نیاز به پیچیدگی و ممنوعیت رمزعبورهای رایج یا اطلاعات شخصی را الزام می‌کند.
- استفاده از راهکارهای مدیریت رمزعبور (Password Vaults یا PAM) توصیه می‌شود تا رمزعبورهای منحصر به فرد و پیچیده تضمین شده و به طور خودکار به روز شوند.
- مکانیسم‌های قفل کردن حساب پس از تعداد مشخصی تلاش ناموفق ورود باید فعال شود و تنظیمات Smart Lockout در Azure AD به روز شود.
- غیرفعال کردن Basic Authentication که اعتبارها را به صورت متن ساده ارسال می‌کند، نیز می‌تواند ریسک‌ها را کاهش دهد.
- آموزش کاربران در مورد تقویت رمزعبور خوب و شناسایی تلاش‌های فیشینگ حیاتی است.



۳.۲ LLMNR Poisoning :

حمله مسموم‌سازی LLMNR از پروتکل‌های حل نام محلی مانند Link-Local Multicast Name Resolution (LLMNR) و NetBIOS Name Service (NBT-NS) سوءاستفاده می‌کند. این پروتکل‌ها به عنوان مکانیزم جایگزین زمانی که سیستم نام دامنه (DNS) در حل نام میزبان شکست می‌خورد، استفاده می‌شوند. مهاجم از این آسیب‌پذیری برای جعل پاسخ‌ها در شبکه محلی استفاده می‌کند که منجر به رهگیری درخواست‌های دستگاه و سرقت هش‌های رمزعبور (NTLM Hashes) می‌شود.



• نحوه عملکرد حمله:

وقتی یک رایانه در حل نام میزبان از طریق DNS شکست می‌خورد، به استفاده از LLMNR یا NBT-NS روی می‌آورد. مهاجم با استفاده از ابزاری مانند Responder، به این درخواست‌ها در شبکه محلی گوش می‌دهد. هنگامی که یک دستگاه درخواستی برای یک نام وجود نداشته یا غیرقابل حل ارسال می‌کند، مهاجم خود را به جای میزبان درخواستی جا زده و با آدرس IP خود پاسخ می‌دهد. دستگاه قربانی تصور می‌کند که به منبع صحیح متصل شده و اعتبارنامه‌های خود (معمولاً هش‌های NTLMv2) را به سرور مهاجم ارسال می‌کند. سپس مهاجم می‌تواند سعی کند این هش‌ها را به صورت آفلاین کرک کرده تا رمزعبورهای متنی ساده به دست آورد، یا از آن‌ها در حملات Pass-the-Hash یا NTLM Relay برای دسترسی مستقیم به سایر



سیستم‌ها بدون نیاز به کرک رمزعبور واقعی استفاده کند. این احراز هویت اغلب بدون تعامل کاربر اتفاق می‌افتد.

• ابزارهای رایج:

Responder رایج‌ترین ابزار برای انجام حملات مسموم‌سازی LLMNR است. از `ntlmrelayx.py` نیز می‌توان برای انجام حملات NTLM Relay در conjunction با Responder استفاده کرد.

• تأثیر و ریسک‌ها:

حملات مسموم‌سازی LLMNR می‌تواند منجر به سرقت اعتبارنامه، دسترسی غیرمجاز و افزایش امتیاز در شبکه شود. از آنجایی که این پروتکل‌ها به طور پیش‌فرض در سیستم‌های ویندوز مدرن فعال هستند و نیاز به احراز هویت ندارند، یک آسیب‌پذیری امنیتی قابل توجه ایجاد می‌کنند. مهاجم می‌تواند به یک "مرد میانی" تبدیل شده و داده‌های حساس را رهگیری کند.

• تشخیص و پاسخ:

برای تشخیص حملات مسموم‌سازی LLMNR، باید ترافیک شبکه برای فعالیت‌های غیرعادی حل نام زیر نظر گرفته شود. ابزارهایی مانند Wireshark یا tcpdump می‌توانند به تحلیل الگوهای ترافیک LLMNR/NBT-NS کمک کنند. هر دستگاهی که به کوئری‌های LLMNR پاسخ می‌دهد و یک Domain Controller نیست باید بررسی شود. همچنین به دنبال بسته‌های احراز هویت NTLM ارسال شده به آدرس‌های IP ناشناخته یا غیرمنتظره و همچنین اشتباهات تایپی در ترافیک LLMNR، DNS و SMB باشید. سیستم‌های تشخیص نفوذ (IDS) و پیشگیری از نفوذ (IPS) می‌توانند برای نظارت بر فعالیت‌های مشکوک استفاده شوند.



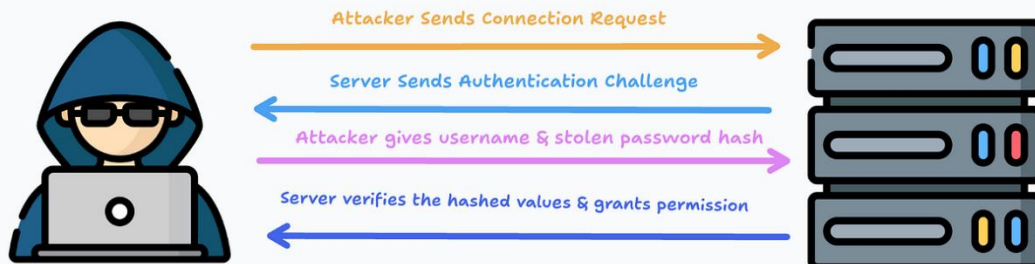
• راهکارهای کاهش و پیشگیری:

آسان‌ترین و مؤثرترین راه برای جلوگیری از این حملات، غیرفعال کردن کامل پروتکل‌های LLMNR و NBT-NS روی رایانه‌ها و سرورها، **either** به صورت مستقیم یا از طریق Group Policy Object (GPO) است. اطمینان حاصل کنید که زیرساخت DNS قوی و قابل اعتماد است تا نیاز به این پروتکل‌های جایگزین کاهش یابد. تقسیم‌بندی شبکه برای ایزوله کردن سیستم‌های حساس توصیه می‌شود. استفاده از رمزعبورهای طولانی و پیچیده نیز شانس کرک هش‌های دزدیده شده را کاهش می‌دهد. آموزش کارکنان در مورد آگاهی امنیتی و گزارش رفتارهای غیرعادی مهم است.

۴.۲ Pass-the-Hash (PtH) :

Pass-the-Hash (PtH) یک تکنیک سوءاستفاده از اعتبار است که به مهاجم اجازه می‌دهد از یک هش رمزعبور دزدیده شده برای ورود به سیستم‌ها و منابع استفاده کند، بدون اینکه نیاز به دانستن رمزعبور اصلی به صورت متن ساده داشته باشد. این حمله از این واقعیت سوءاستفاده می‌کند که سیستم‌های ویندوز، به ویژه هنگام استفاده از پروتکل NTLM برای احراز هویت، می‌توانند هویت کاربر را با استفاده از هش به جای خود رمزعبور تأیید کنند.

Pass The Hash Attack





• نحوه عملکرد حمله:

یک حمله Pth با نفوذ اولیه مهاجم به شبکه آغاز می‌شود، که اغلب از طریق تکنیک‌های مهندسی اجتماعی مانند فیشینگ، بدافزار یا سوءاستفاده از آسیب‌پذیری‌ها برای دسترسی محلی به یک رایانه صورت می‌گیرد. پس از دسترسی، مهاجم هش‌های رمزعبور را از حافظه سیستم (مانند فرآیند LSASS)، پایگاه داده Active Directory (NTDS.dit) یا Security Accounts Manager (SAM) استخراج می‌کند. به جای کرک این هش‌ها برای به دست آوردن رمزعبورهای متنی ساده، مهاجم هش را مستقیماً به سیستم دیگری در شبکه «پاس» می‌دهد تا برای احراز هویت استفاده شود. از آنجایی که سیستم برای احراز هویت به مقایسه هش متکی است، هش ارائه شده را تأیید کرده و به مهاجم دسترسی می‌دهد. این امر به مهاجم اجازه می‌دهد به صورت جانبی در شبکه حرکت کند، اعتبارنامه‌های بیشتری جمع‌آوری کرده و تا رسیدن به حساب‌های مدیریتی با امتیازات بالا، پیشروی کند.

• ابزارهای رایج:

Mimikatz شناخته‌شده‌ترین ابزار برای انجام حملات Pth است، زیرا می‌تواند رمزعبورها و هش‌های متنی ساده را از حافظه استخراج کند. سایر ابزارها شامل wce، SharpKatz، Invoke-TheHash، Sharp-SMBExec، Metasploit، Gsecdump، Windows Credentials Editor (WCE)، fgdump و pwdump7 هستند.

• تأثیر و ریسک‌ها:

حملات Pth بسیار خطرناک و تشخیص آنها دشوار است زیرا از اعتبارنامه‌های «قانونی» و پروتکل‌های شبکه استفاده می‌کنند و مهاجم را به عنوان یک کاربر مجاز نشان می‌دهند. یک حمله موفق می‌تواند منجر به کنترل کامل شبکه، سرقت داده‌های حساس و استقرار باج‌افزار شود. میزان خسارت potential به سطح دسترسی اعتبارنامه‌های به خطر افتاده بستگی دارد؛ اگر حساب compromised شده دارای امتیازات بالا باشد (مانند Domain Administrator)، پیامدها می‌تواند فاجعه‌بار باشد.

• تشخیص و پاسخ:

تشخیص حملات Pth چالش‌برانگیز است، اما نشانه‌های خاصی را می‌توان جستجو کرد. باید لاگ‌های رویداد امنیتی ویندوز را زیر نظر گرفت، به ویژه Event ID 4624 (ورود موفق) با



Logon Type 3 (ورود از طریق شبکه) و بسته احراز هویت NTLM. همچنین به دنبال Event ID 4648 (تلاش موفق برای ورود با اعتبارنامه‌های صریح) و 4672 (امتیازات ویژه اختصاص داده شده به یک ورود جدید) باشید. رفتار غیرعادی کاربر باید نظارت شود، مانند ورود به تعداد میزبان‌های بسیار بیشتر یا دسترسی به میزبان‌هایی که قبلاً با آنها تعامل نداشته است. ابزارهای Endpoint Detection and Response (EDR)، راه‌حل‌های Identity Threat Detection and Response (ITDR) و سیستم‌های SIEM می‌توانند به تشخیص رفتارهای غیرعادی و تلاش برای دسترسی به حافظه‌ای که هش‌های رمزعبور در آن ذخیره شده‌اند، کمک کنند.

• راهکارهای کاهش و پیشگیری:

پیشگیری از حملات PtH نیازمند نیازمند یک رویکرد دفاعی چندلایه. اصل کمترین امتیاز باید به شدت اعمال شود و حقوق administrator محلی برای کاربران عادی محدود شود. احراز هویت چندعاملی (MFA) برای حساب‌های با امتیازات بالا توصیه می‌شود. راه‌حل‌های مدیریت دسترسی امتیازی (PAM) می‌توانند برای چرخش خودکار رمزعبورها پس از هر جلسه privileged استفاده شوند. غیرفعال کردن پروتکل منسوخ شده NTLM، در صورت امکان، یک گام مهم برای کاهش سطح حمله است. Windows Defender Credential Guard و Local Administrator Password Solution (LAPS) می‌توانند به محافظت از اعتبارنامه‌ها در حافظه و اطمینان از رمزعبورهای منحصر به فرد برای حساب‌های administrator محلی کمک کنند. آموزش کارکنان در مورد آگاهی امنیتی برای شناسایی تلاش‌های فیشینگ حیاتی است.

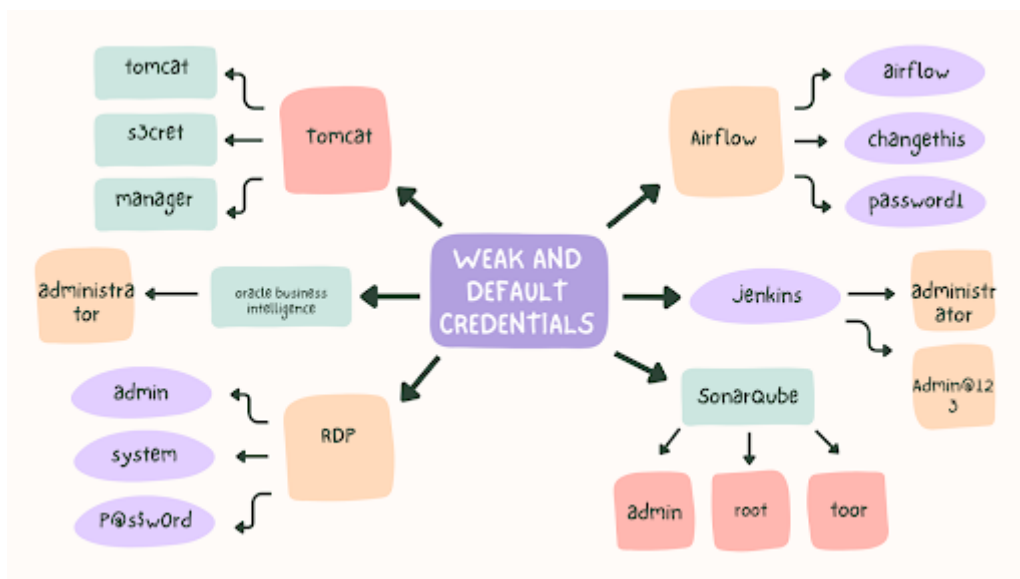
TryHackBox

۵.۲ Default Credentials :

اعتبارنامه‌های پیش فرض Default Credentials به نام‌های کاربری و رمزعبورهای از کارخانه اختصاص یافته‌ای اشاره دارد که روی دستگاه‌ها یا نرم‌افزارها قبل از حمل نصب می‌شوند. این اعتبارنامه‌ها برای ساده‌سازی راه‌اندازی اولیه استفاده می‌شوند اما در صورت عدم تغییر پس از نصب، یک آسیب‌پذیری امنیتی جدی ایجاد می‌کنند. این اعتبارنامه‌ها اغلب ساده هستند،



مانند "admin/admin" یا "root/password" ، و ممکن است در راهنماهای کاربر به صورت عمومی مستند شده یا به راحتی به صورت آنلاین قابل جستجو باشند.



• نحوه عملکرد حمله:

مهاجمان به صورت سیستماتیک از اعتبارنامه‌های پیش‌فرض سوءاستفاده می‌کنند. از ابزارهای اسکن خودکار برای شناسایی سریع دستگاه‌های آسیب‌پذیر در محدوده‌های شبکه استفاده می‌شود. این ابزارها به طور مداوم ترکیبات رایج رمزعبور پیش‌فرض را در برابر سرویس‌های کشف شده امتحان می‌کنند. مهاجمان همچنین می‌توانند از فهرست‌های رمزعبورهای پیش‌فرض شناخته شده در حملات Credential Stuffing استفاده کنند. پس از دسترسی اولیه، مهاجمان می‌توانند به صورت جانبی در شبکه حرکت کرده و امتیازات خود را افزایش دهند، به ویژه اگر دستگاه به خطر افتاده به یک دامنه Active Directory متصل باشد.



• نمونه‌های رایج:

نمونه‌های رایج اعتبارنامه‌های پیش‌فرض شامل موارد زیر است:

- "admin/admin" (برای چاپگرهای HP، روترهای Linksys)
- "cisco/cisco" (برای روترهای سیسکو)
- "root/password" (برای پایگاه‌های داده MySQL)
- "admin/(خالی)" (برای دوربین‌های D-Link)

• ابزارهای رایج:

ابزارهایی مانند Burp Intruder، THC Hydra، Nikto 2 و Nuclei برای تست اعتبارنامه‌های پیش‌فرض استفاده می‌شوند.

• تأثیر و ریسک‌ها:

اعتبارنامه‌های پیش‌فرض یک ریسک قابل توجه ایجاد می‌کنند زیرا یک نقطه ورود آسان برای مهاجمان بدون نیاز به تکنیک‌های هک پیچیده فراهم می‌کنند. اگر این اعتبارنامه‌ها تغییر نکنند، مهاجمان می‌توانند تلاش‌های خود را در چندین سیستم گسترش داده و از یک نقطه ضعف واحد به کل شبکه‌ها دسترسی پیدا کنند. این می‌تواند منجر به نشت داده‌ها، کلاهبرداری مالی و آسیب به اعتبار سازمان شود. این آسیب‌پذیری‌ها همچنین یک ریسک زنجیره تأمین ایجاد می‌کنند، زیرا می‌توانند قبل از رسیدن سیستم به کاربر نهایی مورد سوءاستفاده قرار گیرند.



• تشخیص و پاسخ:

اکثر ابزارهای ارزیابی آسیب پذیری (مانند Nessus، Qualys و Rapid7) شناسایی برنامه‌ها و دستگاه‌های دارای اعتبارنامه‌های پیش فرض فعال را آسان می‌کنند. الگوهای ورود غیرعادی، مانند افزایش ناگهانی تلاش‌های ناموفق ورود یا تحلیل فعالیت IP برای تشخیص حملات توزیع شده، باید زیر نظر گرفته شوند.

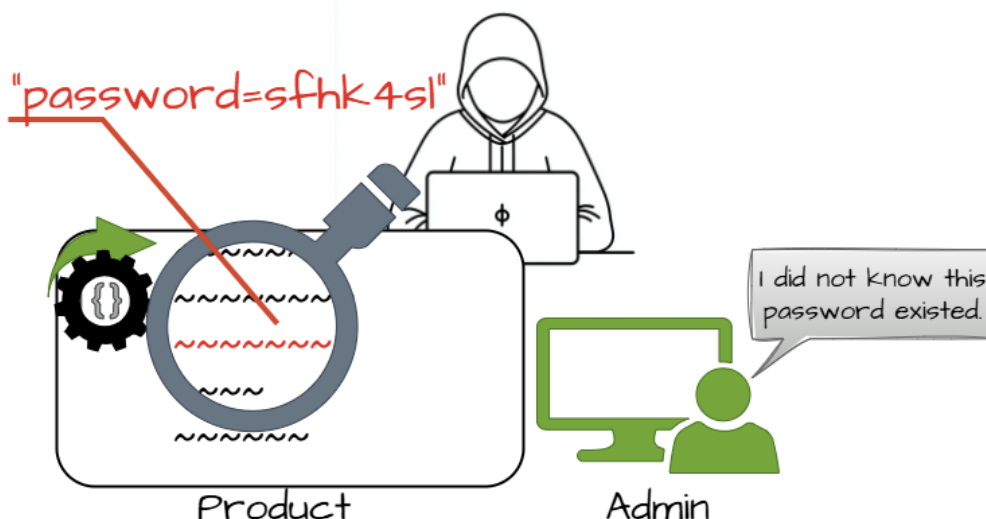
• راهکارهای کاهش و پیشگیری:

مهم‌ترین اقدام پیشگیرانه، تغییر یا غیرفعال کردن فوری اعتبارنامه‌های پیش فرض پس از نصب هر دستگاه یا نرم‌افزاری است. باید سیاست‌های رمز عبور قوی، منحصر به فرد و پیچیده اعمال شود و رمز عبورها در اولین استفاده تغییر کنند. تولیدکننده‌های رمز عبور برای ایجاد رمز عبورهای تصادفی و منحصر به فرد توصیه می‌شوند. راه‌حل‌های مدیریت رمز عبور (PAM) می‌توانند به ذخیره امن رمز عبورهای جدید و چرخش خودکار آنها کمک کنند. حساب‌های استفاده نشده باید غیرفعال شوند. پیاده‌سازی احراز هویت چندعاملی (MFA) یک لایه محافظتی اضافی فراهم می‌کند و حتی اگر مهاجم رمز عبور پیش فرض را به دست آورد، از دسترسی جلوگیری می‌کند. غیرفعال کردن پروتکل NTLM در صورت امکان نیز توصیه می‌شود، زیرا از MFA پشتیبانی نمی‌کند و می‌تواند مورد سوءاستفاده قرار گیرد.

TryHackBox

۶.۲ Hard-coded Credentials:

اعتبارنامه‌های سخت‌افزاری (Hard-coded Credentials) به اطلاعات احراز هویت حساس مانند نام‌های کاربری، رمز عبورها، کلیدهای API و کلیدهای رمزنگاری اشاره دارد که مستقیماً در کد منبع، فایل‌های پیکربندی یا خط‌مشی‌های سیستم جاسازی شده‌اند. در حالی که این روش برای توسعه‌دهندگان در فاز توسعه راحت است، اما در صورت حذف نشدن یا محافظت نشدن کافی قبل از استقرار نرم‌افزار، یک تهدید امنیتی جدی ایجاد می‌کند.



• نحوه عملکرد حمله:

مهاجمان می‌توانند از اعتبارنامه‌های سخت‌افزاری به چندین روش سوءاستفاده کنند. اگر مهاجم به کد منبع برنامه دسترسی پیدا کند (از طریق مهندسی معکوس، نشت داده یا مخازن عمومی مانند GitHub)، به راحتی می‌تواند این اعتبارنامه‌ها را استخراج کرده و از آن‌ها برای دسترسی غیرمجاز به منابع حساس مانند پایگاه‌های داده یا سرویس‌های وب استفاده کند. این اعتبارنامه‌ها اغلب به دلیل ذخیره شدن به صورت متن ساده، به راحتی قابل کشف هستند. پس از استخراج، مهاجم می‌تواند از آن‌ها برای افزایش امتیازات، حرکت جانبی در شبکه‌ها و سرقت داده استفاده کند. در برخی موارد، مهاجمان ممکن است اعتبارنامه‌های سخت‌افزاری را وارد کنند تا درهای پشتی ایجاد کنند که به آن‌ها دسترسی مداوم بدهد.

TryHackBox

• نمونه‌های رایج:

نمونه‌های رایج اعتبارنامه‌های سخت‌افزاری شامل: کلیدهای API، اعتبارنامه‌های پایگاه داده، توکن‌های OAuth، کلیدهای رمزنگاری، کلیدهای خصوصی SSH و اعتبارنامه‌های دسترسی ارائه‌دهندگان ابری (AWS, Azure, GCP) می‌شود. حوادث قابل توجه، مانند نشت داده Uber و Toyota، به دلیل وجود رمزعبورها و کلیدهای AWS سخت‌افزاری در کد منبع یا اسکرپت‌ها رخ داده است.



• ابزارهای رایج:

ابزارهایی مانند Burp Intruder، THC Hydra، Nikto 2 و Nuclei برای تست اعتبارنامه‌های پیش فرض استفاده می‌شوند. ابزارهایی مانند GitGuardian و TruffleHog برای اسکن مخازن عمومی و خصوصی برای یافتن اسرار نشت شده استفاده می‌شوند. ابزارهای تحلیل ترافیک شبکه (مانند Wireshark) و مهندسی معکوس می‌توانند به شناسایی این اعتبارنامه‌ها کمک کنند. راه‌حل‌های Endpoint Detection and Response (EDR)، Extended Detection and Response (XDR) و Managed Detection and Response (MDR) قابلیت‌های پیشرفته تشخیص و پاسخ به تهدیدات را ارائه می‌دهند، از جمله رفتارهای غیرعادی که نشان‌دهنده سوءاستفاده از اعتبارنامه است. فایروال‌های برنامه‌های تحت وب (WAF) نیز می‌توانند از برنامه‌های وب در برابر حملات سوءاستفاده از این آسیب‌پذیری‌ها محافظت کنند.

• تأثیر و ریسک‌ها:

اعتبارنامه‌های سخت‌افزاری ریسک‌های قابل توجهی ایجاد می‌کنند، از جمله افشای اطلاعات حساس، دسترسی غیرمجاز به برنامه‌ها، سیستم‌ها و شبکه‌ها، و تغییر داده. استفاده از همان اعتبارنامه‌های سخت‌افزاری در چندین سیستم می‌تواند منجر به نشت گسترده شود. آن‌ها همچنین یک ریسک زنجیره تأمین ایجاد می‌کنند، زیرا این آسیب‌پذیری‌ها می‌توانند قبل از رسیدن سیستم به کاربر نهایی مورد سوءاستفاده قرار گیرند.

• تشخیص و پاسخ:



برای تشخیص اعتبارنامه‌های سخت‌افزاری، باید بازبینی منظم کد و اسکن آسیب‌پذیری انجام شود. ابزارهای خودکار مانند GitGuardian و TruffleHog می‌توانند برای اسکن مخازن عمومی و خصوصی برای یافتن اسرار نشت شده استفاده شوند. ابزارهای تحلیل ترافیک شبکه (مانند Wireshark) و مهندسی معکوس می‌توانند به شناسایی این اعتبارنامه‌ها کمک کنند. راه‌حل‌های EDR، XDR و MDR قابلیت‌های پیشرفته تشخیص و پاسخ به تهدیدات را ارائه می‌دهند. فایروال‌های برنامه‌های تحت وب (WAF) نیز می‌توانند از برنامه‌های وب در برابر حملات سوءاستفاده از این آسیب‌پذیری‌ها محافظت کنند.

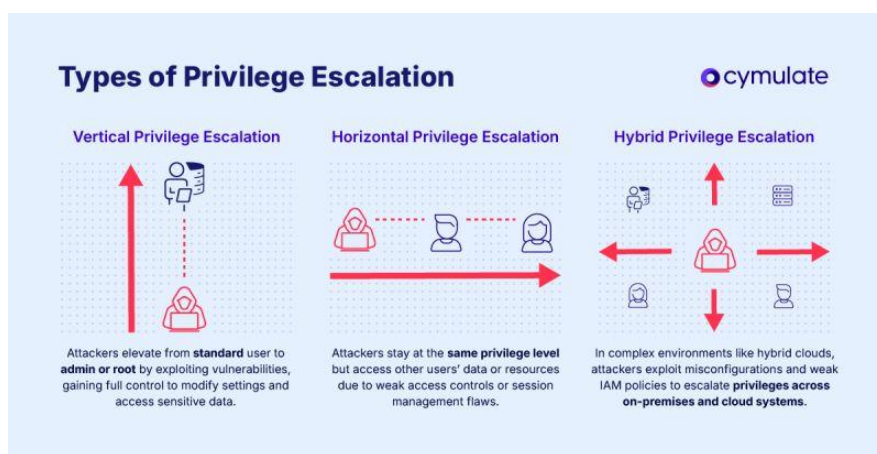
• راهکارهای کاهش و پیشگیری:

باید از کدگذاری سخت اعتبارنامه‌ها مستقیماً در کد منبع خودداری شود. در عوض، اطلاعات حساس باید در متغیرهای محیطی یا فایل‌های پیکربندی ذخیره شوند. استفاده از راه‌حل‌های مدیریت امن اسرار (Secure Key Vaults) مانند HashiCorp Vault، AWS Secrets Manager و Microsoft Azure Key Vault به شدت توصیه می‌شود تا داده‌های حساس با کنترل‌های دسترسی اضافی و رمزنگاری ذخیره شوند. باید رمزنگاری برای محافظت از اطلاعات حساس در حین انتقال و در حالت سکون اعمال شود. کنترل‌های دسترسی سخت‌گیرانه (مانند کنترل دسترسی مبتنی بر نقش) نیز باید اعمال شود. رعایت روش‌های کدنویسی امن، از جمله بازبینی کد و اسکن آسیب‌پذیری، حیاتی است. توسعه‌دهندگان باید آموزش ببینند تا از این روش‌های امنیتی ضعیف اجتناب کنند، مانند استفاده از فایل‌های gitignore برای حذف فایل‌های حساس از commit. سازمان‌ها باید از خرید نرم‌افزار یا سخت‌افزاری که شامل اعتبارنامه‌های سخت‌افزاری است خودداری کنند تا به فروشندگان فشار بیاورند این روش بد را حذف کنند.



۲.۲ Privilege Escalation :

افزایش امتیاز یک حمله سایبری است که با هدف دسترسی غیرمجاز به حقوق، مجوزها یا امتیازات بالاتر از آنچه که به یک هویت، حساب، کاربر یا دستگاه اختصاص داده شده است، انجام می‌شود. مهاجمان اغلب می‌توانند با امتیازات محدود وارد شبکه شوند اما برای دستیابی به اهداف نهایی خود، مانند دسترسی به داده‌های حساس یا کسب کنترل کامل سیستم، به مجوزهای elevated نیاز دارند.



• انواع افزایش امتیاز:

- **افزایش عمودی امتیاز:** زمانی رخ می‌دهد که مهاجم به یک حساب با امتیازات محدود دسترسی پیدا می‌کند، سپس به دنبال راه‌هایی برای افزایش مجوزهای خود با استفاده از همان حساب می‌گردد، مانند افزودن حساب **compromised** شده به گروه **administrators** محلی.

- **افزایش افقی امتیاز:** زمانی رخ می‌دهد که مهاجم به اعتبارنامه‌های دیگر در شبکه با امتیازات مشابه یا بالاتر از آنچه برای نفوذ اولیه استفاده شده است، دسترسی پیدا می‌کند.



• ابزارها و تکنیک‌های رایج:

تکنیک‌های رایج شامل: Kerberoasting، AS-REP Roasting، دستکاری DACL، سوءاستفاده از سرویس‌های گواهی Active Directory (AD CS) و PrintNightmare است. ابزارهایی مانند Mimikatz، PowerSploit و BloodHound در مراحل مختلف حمله استفاده می‌شوند.

• تأثیر و ریسک‌ها:

حملات افزایش امتیاز برای مهاجمان جهت دستیابی به اهدافشان مهم و حیاتی هستند. هنگامی که یک مهاجم به حساب Domain Administrator دسترسی پیدا می‌کند، «کلیدهای پادشاهی» را در اختیار دارد که به او کنترل کامل بر Active Directory و thus کل سیستم اطلاعاتی می‌دهد. تشخیص این حملات بسیار دشوار و غیرقابل پیش‌بینی است، زیرا مهاجمان می‌توانند دسترسی persistent داشته و به عنوان «کاربران قانونی» عمل کنند.

• تشخیص و پاسخ:

تشخیص افزایش امتیاز بر اساس شناسایی الگوها، جستجوی ناهنجاری‌ها و شناسایی رویدادهای غیرعادی است. تغییرات در گروه‌های با امتیاز بالا در Active Directory (مانند Admins) باید نظارت شود، به دنبال درخواست‌های مشکوک بلیط Kerberos باشید و تعداد غیرعادی درخواست‌های بلیط سرویس رایانه را بررسی کنید. سیستم‌های IDS/IPS و EDR می‌توانند یک لایه امنیتی اضافی برای تشخیص تلاش‌های افزایش امتیاز ارائه دهند.

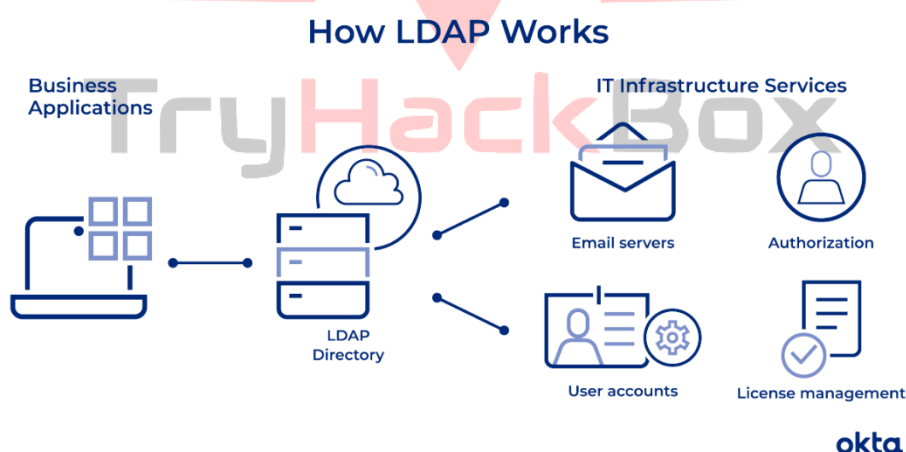
• راهکارهای کاهش و پیشگیری:



یک استراتژی دفاع در عمق ضروری است. اصل کمترین امتیاز باید به شدت اعمال شود و به کاربران و حسابهای سرویس حداقل مجوزهای لازم برای انجام تابع شان اعطا شود. تقسیم‌بندی شبکه با استفاده از یک مدل Tier توصیه می‌شود تا سیستم‌ها و منابع حیاتی ایزوله شده و از افزایش امتیاز از ایستگاه‌های کاری کاربران به Domain Controllers جلوگیری شود. سیاست‌های رمزعبور قوی باید اجرا شود و احراز هویت چندعاملی (MFA) برای حسابهای privileged اعمال شود. ممیزی منظم رمزعبور حسابهای Active Directory، از جمله حسابهای سرویس، حیاتی است. سیستم‌ها و برنامه‌ها باید به طور منظم به‌روزرسانی و patch شوند تا آسیب‌پذیری‌های امنیتی رفع شوند. آموزش کارکنان در مورد آگاهی امنیتی نیز ریسک‌های مهندسی اجتماعی را کاهش می‌دهد.

۸.۲ LDAP Reconnaissance

LDAP (Lightweight Directory Access Protocol) یک تکنیک حیاتی است که توسط مهاجمان برای جمع‌آوری اطلاعات درباره ساختار داخلی Active Directory استفاده می‌شود. از طریق کوئری‌های LDAP، مهاجمان می‌توانند جزئیات ارزشمندی درباره یک سازمان، مانند حسابهای کاربری، گروه‌ها، رایانه‌ها و امتیازات را کشف کنند، گاهی حتی بدون احراز هویت.





• نحوه عملکرد حمله:

پس از آن که مهاجم دسترسی اولیه به یک رایانه متصل به دامنه (از طریق فیشینگ یا سایر روش‌ها) به دست آورد، می‌تواند با استفاده از پروتکل LDAP شروع به پرس‌وجو از دایرکتوری و اشیاء آن کند. به طور طراحی‌شده، پروتکل LDAP به کاربران عادی دامنه اجازه می‌دهد داده‌های دایرکتوری را بدون نیاز به امتیازات **elevated** بخوانند. از طریق این کوئری‌ها، مهاجمان می‌توانند اطلاعاتی درباره موارد زیر جمع‌آوری کنند: نام‌های کاربری، گروه‌ها، رایانه‌ها، **Service Principal Names (SPNs)**، عضویت در گروه‌های حساس (مانند **Domain Admins**) و مکان دارایی‌های باارزش (مانند سرورهای فایل، پایگاه‌های داده و **Domain Controllers**). این اطلاعات سپس برای شناسایی اهداف باارزش و برنامه‌ریزی مسیرهای حمله بعدی، مانند افزایش امتیاز و حرکت جانبی، استفاده می‌شود.

• ابزارهای رایج:

ابزارهای رایج مورد استفاده در شناسایی LDAP شامل موارد زیر است:

Active Directory Explorer

AdFind

ADRecon

SharpHound (بخشی از BloodHoundAD)

PowerSploit (PowerView)

این ابزارها توسط گروه‌های تهدید مداوم پیشرفته (APT) و باندهای باج‌افزار استفاده می‌شوند.

• تأثیر و ریسک‌ها:

شناسایی LDAP یک قدم اولیه مهم و حیاتی در بیشتر حملات **Active Directory** است. این امر به مهاجمان اجازه می‌دهد یک «نقشه» از شبکه ایجاد کنند، که شناسایی آسیب‌پذیری‌ها و ارزشمندترین اهداف را برای آن‌ها آسان‌تر می‌کند. از آنجایی که پروتکل LDAP



frequently در عملیات عادی Active Directory استفاده می‌شود، تشخیص کوئری‌های مخرب از کوئری‌های legitimate دشوار است و این امر تشخیص را به یک چالش تبدیل می‌کند. افشای اطلاعات حساس درباره ساختار شبکه و حساب‌های کاربری می‌تواند منجر به حملات بعدی پیچیده‌تر شود.

• تشخیص و پاسخ:

تشخیص بهترین دفاع در برابر شناسایی LDAP است. راه‌حل‌های EDR که از Microsoft-ETW Provider Windows-LDAP-Client استفاده می‌کنند، می‌توانند کوئری‌های مشکوک LDAP را تشخیص دهند. نظارت بر شبکه باید برای تحلیل ترافیک LDAP پیاده‌سازی شود، به دنبال الگوهای کوئری غیرعادی یا گسترده، یا هدف قرار دادن حساب‌ها و گروه‌های administrative باشد. سیستم‌های SIEM می‌توانند به جمع‌آوری و تحلیل لاگ‌ها برای شناسایی فعالیت‌های غیرعادی کمک کنند. اگر شناسایی LDAP تشخیص داده شود، فرآیند پاسخ به حادثه باید بلافاصله فعال شود، حساب کاربری performing شناسایی password reset و غیرفعال شود، و دستگاه مبدأ برای تحقیقات forensics ایزوله شود.



• راهکارهای کاهش و پیشگیری:

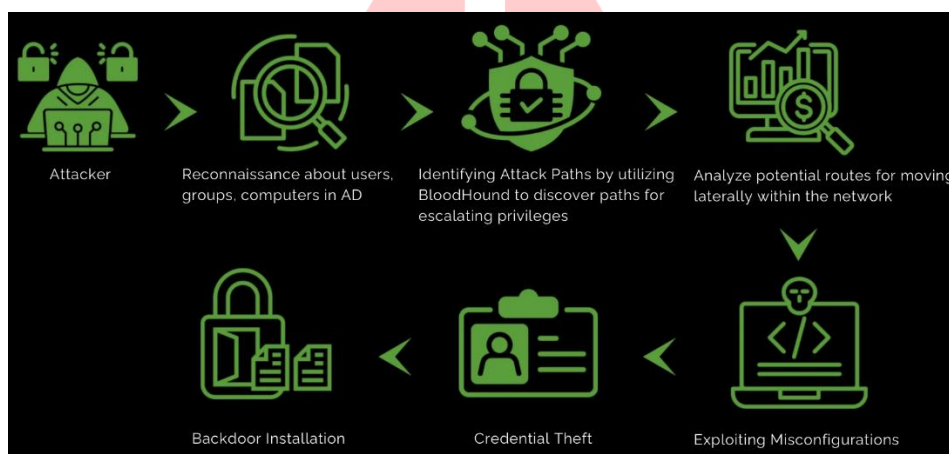
به دلیل نقش essential LDAP در عملیات عادی Active Directory، سازمان‌ها نمی‌توانند به سادگی استفاده از آن را مسدود کنند. در عوض، تمرکز باید بر روی اقدامات کاهش باشد که از نفوذ اولیه جلوگیری می‌کنند، مانند: آموزش آگاهی امنیتی کاربران، تشخیص و پاسخ endpoint، تشخیص و پیشگیری فیشینگ، امنیت ایمیل و احراز هویت چندعاملی (MFA). اصل کمترین امتیاز باید به شدت اعمال شود، تا به حساب‌ها امتیازات excessive اعطا نشود. پیاده‌سازی یک مدل administrative طبقه‌بندی شده برای Active Directory



توصیه می‌شود تا حقوق دسترسی به شدت کنترل شده و مسیرهای حمله کاهش یابد. Domain Controllers نیز باید با اعمال اصول میزبان administrative امن، ایمن شوند.

۹.۲ BloodHound Reconnaissance :

BloodHound یک ابزار منبع باز است که از تئوری گراف برای شناسایی روابط پنهان و مسیرهای افزایش امتیاز در محیط‌های Active Directory استفاده می‌کند. این ابزار به طور گسترده توسط هر دو گروه مهاجمان و مدافعان (تیم‌های قرمز و آبی) برای تحلیل امنیت دامنه Active Directory استفاده می‌شود.



• نحوه عملکرد حمله:

فرآیند BloodHound با جمع‌آوری حجم زیادی از داده از دامنه Active Directory با استفاده از ابزارهای جمع‌آوری داده مانند SharpHound (نوشته شده با #C) یا AzureHound آغاز می‌شود. این کار با اتصال به چندین میزبان از طریق پورت‌هایی مانند ۱۳۷ و ۴۴۵ و همچنین اتصالات Named Pipe انجام می‌شود. پس از جمع‌آوری داده (معمولاً در فایل‌های فشرده JSON)، داده‌ها در رابط گرافیکی کاربر BloodHound (GUI) بارگذاری می‌شوند.



BloodHound از تئوری گراف برای نمایش روابط پیچیده بین اشیاء **Active Directory** (مانند کاربران، گروه‌ها، رایانه‌ها) استفاده می‌کند و کوتاه‌ترین مسیرهای حمله که می‌تواند منجر به امتیازات بالا، مانند دسترسی به گروه **Domain Admins** شود را شناسایی می‌کند. مهاجم از این مسیرهای شناسایی‌شده برای برنامه‌ریزی دقیق حملات افزایش امتیاز و حرکت جانبی استفاده می‌کند.

• ابزارهای رایج:

ابزارهای اصلی شامل **SharpHound** و **AzureHound** برای جمع‌آوری داده و **BloodHound.py** (که اجازه جمع‌آوری اطلاعات از سیستم‌های لینوکس، macOS و ویندوز را می‌دهد) هستند.

• تأثیر و ریسک‌ها:

BloodHound به مهاجمان یک نقشه راه واضح و دقیق برای کسب بالاترین امتیازات در داخل **Active Directory** ارائه می‌دهد. این ابزار **commonly** در نفوذهای باج‌افزار استفاده می‌شود. چالش اصلی این است که **BloodHound** یک «شمشیر دو لبه» است؛ هم برای مهاجمان و هم برای مدافعان مفید است. تشخیص بین استفاده **legitimate** (برای ممیزی امنیتی) و استفاده **malicious** می‌تواند دشوار باشد و نیازمند درک قوی از استفاده مجاز از ابزار در محیط است. این واقعیت که یک ابزار قدرتمند مانند **BloodHound**، که برای نقشه‌برداری روابط پیچیده طراحی شده است، می‌تواند به یک اندازه برای اهداف تهاجمی و دفاعی مؤثر باشد، نشان می‌دهد که تیم‌های دفاعی باید از آن برای درک آسیب‌پذیری‌های محیط خود استفاده کنند، زیرا مهاجمان **certainly** این کار را خواهند کرد.



• تشخیص و پاسخ:

برای تشخیص فعالیت BloodHound، فعالیتهای مرتبط با SMB و Named Pipe باید نظارت شوند. استفاده از SharpHound می‌تواند از طریق گزینه‌های رایج خط فرمان یا الگوهای اتصال تشخیص داده شود. فعالیتهای SharpHound همچنین می‌تواند در داده‌های LDAP جستجو شود. ابزارهایی مانند AD-RECON (از BreakPoint Labs) برای triage سریع داده‌های BloodHound و شناسایی مسیرهای حمله potential استفاده می‌شوند. Reflective.NET assembly loading در حافظه، که SharpHound از آن برای جلوگیری از تشخیص دیسک استفاده می‌کند، نیز باید تشخیص داده شود. در صورت تشخیص، دستگاه مبدأ باید ایزوله شود، اعتبارنامه‌های compromised reset شود و مسیرهای حمله شناسایی شده تحلیل شوند.

• راهکارهای کاهش و پیشگیری:

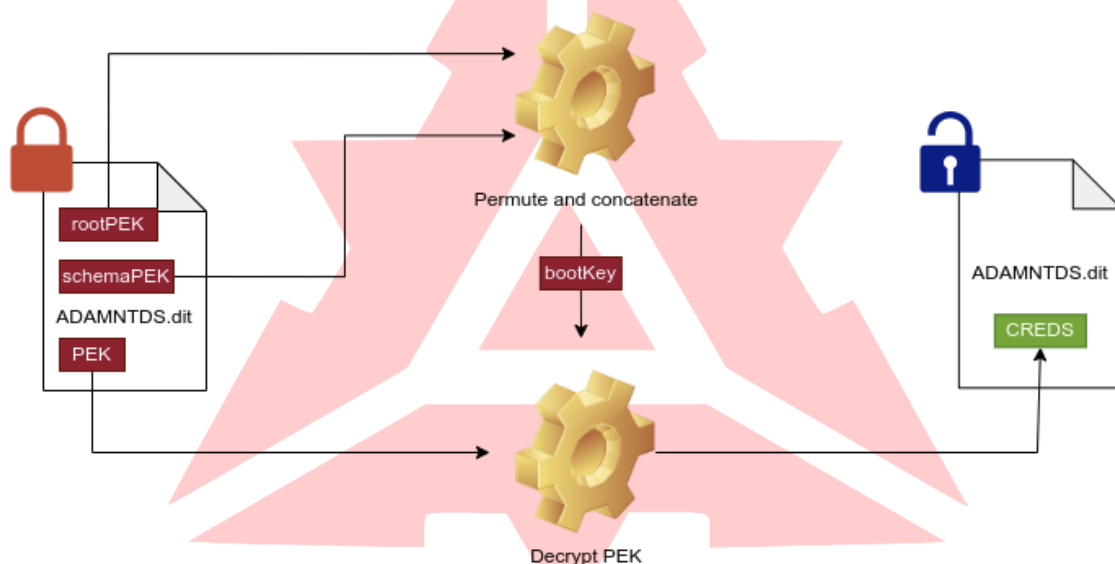
پیشگیری از حملات BloodHound نیازمند اعمال سختگیری اصل کمترین امتیاز است. تقسیم‌بندی شبکه برای ایزوله کردن سیستم‌ها و منابع حیاتی یک گام مهم و حیاتی است. Group Policy Objects (GPOs) باید ایمن شده و به طور منظم ممیزی شوند. حذف روابط پنهان و ناخواسته‌ای که ممکن است ریسک ایجاد کنند، مهم است. احراز هویت چندعاملی (MFA) توصیه می‌شود. سیستم‌ها باید به طور منظم به‌روزرسانی و patch شوند تا آسیب‌پذیری‌های امنیتی کاهش یابد. سازمان‌ها می‌توانند از BloodHound به عنوان یک ابزار دفاعی برای انجام ممیزی ریسک و شناسایی مسیرهای حمله potential قبل از مهاجمان استفاده کنند. آموزش کارکنان و آگاهی امنیتی حیاتی است. استفاده از BloodHound توسط هر دو گروه مهاجمان و مدافعان نشان می‌دهد که سازمان‌ها نمی‌توانند ابزارهای شناسایی پیشرفته را نادیده بگیرند؛ استفاده proactive از ابزارهایی مانند BloodHound در تمرینات «Red Teaming» و «Purple Teaming» (جایی که تیم‌های دفاعی از



ابزارهای تهاجمی استفاده می کنند) essential است تا مسیرهای حمله قبل از سوءاستفاده مهاجمان شناسایی و رفع شوند.

۱۰.۲ NTDS.dit Extraction :

استخراج فایل NTDS.dit یک حمله extremely dangerous است که aimed at سرقت فایل اصلی پایگاه داده Active Directory است که شامل تمام حسابهای کاربری، هشهای رمز عبور و سایر اطلاعات حساس است. این حمله به عنوان یک «تاکتیک حمله اصلی» referred to می شود زیرا به مهاجم «کلیدهای پادشاهی» را اعطا می کند، به معنای کنترل کامل بر محیط Active Directory.



• نحوه عملکرد حمله: TryHackBox

این حمله نیازمند دسترسی administrative به یک Domain Controller است. مهاجمان می توانند فایل NTDS.dit را مستقیماً در حالی که Domain Controller در حال اجرا است با استفاده از ابزارهایی مانند ntdsutil.exe (که می تواند یک Volume Shadow Copy یا Installation Media ایجاد کند)، diskshadow، wmic یا esentutl کپی کنند. فایل همچنین می تواند از backupهای Domain Controller استخراج شود. برای رمزگشایی هشهای رمز عبور در فایل NTDS.dit، مهاجم همچنین needs به استخراج فایل SYSTEM hive از رجیستری سیستم همان Domain



Controller دارد، زیرا این فایل حاوی کلید رمزگذاری (Boot Key) است. پس از به دست آوردن هر دو NTDS.dit و SYSTEM hive، مهاجمان می‌توانند هش‌های رمزعبور را به صورت آفلاین crack کنند (با استفاده از ابزارهایی مانند secretsdump.py، ntdsextract، NTDSDumpEx، Quarkspwdump، ntdissector) یا مستقیماً از آن‌ها در حملات Pass-the-Hash برای دسترسی به سیستم‌ها بدون نیاز به crack کردن رمزعبورها استفاده کنند.

• ابزارهای رایج:

ابزارهای رایج مورد استفاده در استخراج NTDS.dit شامل موارد زیر است: ntdsutil.exe، secretsdump.py، ntdsextract، NTDSDumpEx، Invoke-NinjaCopy، esentutl، diskshadow، wmic، Quarkspwdump و ntdissector.

• تأثیر و ریسک‌ها:

یک حمله موفق استخراج NTDS.dit منجر به کنترل کامل بر تمام حساب‌های Active Directory، از جمله حساب‌های Domain Admin می‌شود. مهاجم possesses تمام هش‌های رمزعبور برای کاربران و دستگاه‌ها در دامنه است. این حمله particularly difficult to detect است اگر استخراج از یک shadow copy یا backup performed شود، زیرا سیستم‌های نظارت سنتی ممکن است alerts صادر نکنند. فایل NTDS.dit «جواهر تاج» در یک محیط Active Directory است، و این واقعیت که می‌تواند نه تنها از Domain Controller های زنده بلکه از backup ها compromised شود، یک ملاحظه امنیت زنجیره تأمین critical است. اگر راه‌حل backup itself کمتر از Domain Controller امن باشد، به یک در پستی برای دسترسی به حساس‌ترین داده‌ها تبدیل می‌شود.



- تشخیص و پاسخ:

برای تشخیص تلاش‌های استخراج NTDS.dit، استفاده از ntdsutil.exe در خط فرمان باید نظارت شود، especially هنگام استفاده از پارامترهای activate instance ntds و ifm. any processes که attempt به دسترسی به فایل ntds.dit یا کپی کردن فایل‌های SYSTEM hive should also be monitored. تغییرات غیرعادی در فضای دیسک آزاد می‌تواند نشان‌دهنده ایجاد shadow copies باشد. راه‌حل‌های نظارت پیشرفته مانند Semperis DSP یا Microsoft Defender for Identity visibility جامع و هشدارهای real-time در مورد تغییرات irregular و دسترسی غیرمجاز به فایل NTDS.dit ارائه می‌دهند. در صورت تشخیص، طرح پاسخ به حادثه باید بلافاصله activated شود، Domain Controller affected isolated شود، رمزعبورهای تمام حساب‌ها reset شود و یک بررسی forensics thorough انجام شود.

- راهکارهای کاهش و پیشگیری:

برای کاهش ریسک‌های استخراج NTDS.dit، تعداد حساب‌هایی که می‌توانند به Domain Controller ها وارد شوند باید حداقل رسانی d شود. اصل «منبع تمیز» باید برای Domain Controller ها applied شود، به این معنی که تمام زیرساخت و برنامه‌هایی که به Domain Controller ها سرویس می‌دهند (مانند ESX، storage متصل، نرم‌افزار themselves must (backup در همان سطح امنیتی Domain Controller ها crucial است. احراز هویت چندعاملی (MFA) برای حساب‌های privileged توصیه می‌شود. یک مدل administrative طبقه‌بندی شده برای Active Directory نیز باید implemented شود. پاکسازی منظم Active Directory، از جمله Group Policy.



یک گام important است. LSA Protection، گروه Protected Users و حالت Restricted Admin برای Remote Desktop باید enabled شود. سیستم‌ها باید به طور منظم به‌روزرسانی و patch شوند تا آسیب‌پذیری‌های امنیتی کاهش یابد.

بخش سوم :

راهنمای جامع برای افزایش امنیت Active Directory

هیچ راه‌حل امنیتی واحدی نمی‌تواند محافظت کامل برای Active Directory را تضمین کند. دفاع در برابر حملات پیچیده ذکر شده above، نیازمند اتخاذ یک استراتژی -Defense-in-Depth است که ترکیبی از کنترل‌های فنی، عملیات امنیتی و آموزش انسانی است.

اجرای اصل کمترین امتیاز (Principle of Least Privilege)

این اصل یک خط دفاعی اساسی و سنگ بنای هر استراتژی امنیتی robust است. این اصل شامل اعطای تنها حداقل مجوزهای لازم به کاربران و حساب‌های سرویس برای انجام تابع و کارهای شان است و اجتناب از استفاده از حساب‌های با امتیاز بالا برای وظایف اداری روزمره. همچنین باید عضویت‌های دائمی در گروه‌های با امتیاز بالا حذف شود و دسترسی موقت فقط در صورت نیاز ارائه شود. این اصل به طور قابل توجهی impact هر نفوذ اولیه را کاهش می‌دهد، زیرا توانایی مهاجم برای حرکت جانبی و افزایش امتیازات را محدود می‌کند حتی اگر یک حساب compromised شود.



سیاست‌های رمز عبور قوی و احراز هویت چندعاملی (MFA)

سیاست‌های رمز عبور قوی و احراز هویت چندعاملی یک دفاع اساسی در برابر بیشتر حملات **Active Directory** که به اعتبارنامه‌ها متکی هستند، تشکیل می‌دهند. باید رمز عبورهای طولانی (حداقل ۱۵-۱۲ کاراکتر، ترجیحاً ۳۰+ کاراکتر)، پیچیده (شامل حروف بزرگ و کوچک، اعداد، نمادها) و منحصر به فرد (عدم استفاده مجدد) اجرا شود. رمز عبورهای رایج یا **leaked** باید ممنوع شوند. استفاده از **Group Managed Service Accounts (gMSAs)** برای حساب‌های سرویس یک گام مهم برای افزایش امنیت است.

احراز هویت چندعاملی (MFA) برای همه حساب‌ها، به ویژه حساب‌های **administrative** و **privileged**، و نقاط حساس احراز هویت مانند **VPN** ها و سرویس‌های ابری ضروری است. **MFA** به طور قابل توجهی اثرگذاری سرقت رمز عبور و هش را کاهش می‌دهد، زیرا یک لایه تأیید اضافی اضافه می‌کند که مهاجمان حتی در صورت به دست آوردن رمز عبور به راحتی نمی‌توانند از آن عبور کنند.

نظارت و ثبت رویدادها

تشخیص زودهنگام کلید حداقل رسانی کردن تاثیرات ثانوی حمله است. نظارت مستمر بر رویدادها در **Active Directory Domain Controllers** و سایر سیستم‌ها مهم و حیاتی است. سیستم‌های **SIEM** و **EDR** باید برای تشخیص الگوهای غیرعادی، رفتارهای غیرمتعارف و تلاش‌های ورود مشکوک استفاده شوند. تغییرات در **Active Directory** **objects** حساس و **Group Policy Objects** نیز باید نظارت شوند. حتی اگر یک مهاجم در یک قدم اولیه موفق شود، نظارت مؤثر می‌تواند پیشرفت آن‌ها را قبل از دستیابی به اهداف نهایی متوقف کند.



تقسیم‌بندی شبکه و ایزوله کردن سیستم‌های حساس

تقسیم‌بندی شبکه یک گام مهم برای ایجاد «موانع» است که سختی حرکت جانبی را برای مهاجمان افزایش می‌دهد و به تیم‌های امنیتی زمان بیشتری برای تشخیص و پاسخ می‌دهد. شبکه باید به zones یا منطقه ایزوله تقسیم شود (مانند Tier Model توصیه شده توسط ANSSI) تا از حرکت جانبی مهاجمان جلوگیری شود. Domain Controllers و سایر سیستم‌های با امتیاز بالا باید در سطوح امنیتی special ایزوله شوند. فایروال‌های میزبان نیز باید برای کنترل و ایمن‌سازی ارتباطات استفاده شوند.

مدیریت آسیب‌پذیری و وصله‌گذاری

آسیب‌پذیری‌های وصله‌نشده نقاط ورود اصلی برای مهاجمان هستند. وصله‌های امنیتی و به‌روزرسانی‌های سیستم عامل/برنامه باید به طور منظم اعمال شوند. سیستم‌ها و برنامه‌های قدیمی یا بدون پشتیبانی باید حذف یا ایزوله شوند تا از سوءاستفاده از آسیب‌پذیری‌های شناخته شده جلوگیری شود. همچنین باید ارزیابی‌های منظم آسیب‌پذیری و تست‌های نفوذ برای شناسایی نقاط ضعف قبل از سوءاستفاده مهاجمان انجام شود. یک برنامه قوی مدیریت آسیب‌پذیری به طور قابل توجهی سطح حمله را کاهش می‌دهد.

TryHackBox

آگاهی امنیتی و آموزش

عنصر انسانی **often weakest link** در زنجیره امنیتی است. کارکنان باید در مورد ریسک S فیشینگ، مهندسی اجتماعی و اهمیت رمز عبورهای قوی آموزش ببینند. به کارکنان باید آموزش داده شود که چگونه فعالیت‌های مشکوک را گزارش دهند. آگاهی مؤثر می‌تواند کاربران را از vulnerabilities به یک خط دفاعی اولیه تبدیل کند.



ابزارهای پیشرفته تشخیص و پاسخ (EDR/SIEM)

سرمایه‌گذاری در راه‌حل‌های EDR، SIEM و ITDR برای تشخیص حملات پیچیده که ممکن است از کنترل‌های سنتی عبور کنند، و برای ارائه قابلیت‌های پاسخ سریع به حداقل رسانی کردن آسیب ضروری است. این ابزارها visibility جامعی در شبکه، endpoints و هویت‌ها ارائه می‌دهند که امکان تشخیص رفتارهای غیرعادی و هشدارهای real-time را فراهم می‌کند. همچنین باید تهدیددییابی پیشگیرانه اعمال شود تا حملات پنهانی که ممکن است از تشخیص خودکار فرار کنند، شناسایی شوند.

بخش چهارم:

ساخت یک دفاع مقاوم در برابر حملات Active Directory

ده روش حمله ذکر شده در بالا نشان می‌دهد که Active Directory همچنان یک هدف اصلی برای مهاجمان باقی مانده است و compromise آن می‌تواند پیامدهای شدیدی برای هر سازمانی داشته باشد. هیچ راه‌حل واحدی تضمین محافظت کامل نمی‌دهد؛ دفاع مؤثر نیازمند یک رویکرد راهبردی چندلایه معروف به "Defense-in-Depth" است. سازمان‌ها باید بر روی یک مجموعه یکپارچه از کنترل‌های فنی قوی، عملیات امنیتی robust و آگاهی انسانی تمرکز کنند.

با پیاده‌سازی اصل کمترین امتیاز، اجرای سیاست‌های رمزعبور قوی، فعال‌سازی احراز هویت چندعاملی، نظارت مستمر بر رویدادها، تقسیم‌بندی شبکه، مدیریت مؤثر آسیب‌پذیری‌ها، آموزش کارکنان و سرمایه‌گذاری در ابزارهای پیشرفته تشخیص و پاسخ، سازمان‌ها می‌توانند یک دفاع مقاوم بسازند که به طور قابل توجهی سطح حمله را کاهش داده و توانایی آن‌ها را برای تشخیص



و پاسخ به حملات قبل از ایجاد خسارت قابل توجه افزایش می دهد. محافظت از Active Directory فقط یک وظیفه فنی نیست، بلکه یک تعهد راهبردی برای تضمین تداوم کسب و کار و امنیت داده های حساس است.

